DEALFLOW_INTEGRATION_READINESS.md

CAUL AI × Deal Flow OS — Phase 0 Discovery & Architecture Readiness

Owner: Cauldron Technologies, Inc. **Status:** Phase 0 (read-only discovery) — **no implementation authorized.**
Prepared by: CAUL AI engineering (E1). **Date:** 2026-06.
Scope guardrail honored: No changes to either live app, no deploys, no migrations, no external spend, no production credentials, no customer-record access. Deal Flow OS was observed only via its **public** marketing site.

---

1. Verified architecture & outstanding unknowns

1A. CAUL AI (this project) — VERIFIED from source

Area	Finding	Evidence
Phase / acceptance	**Phase 1A ACCEPTED & closed**; 100% backend coverage enforced (123 tests, `fail_under=100`).	`memory/PRD.md`, `docs/PHASE_1A_ACCEPTANCE_CERTIFICATE.pdf`, `.coveragerc`
Auth	**Provider-neutral OIDC/OAuth2 interface + labeled STUB** (`StubIdentityProvider`). **No production IdP.** JWT httpOnly sessions, server-side revocation, 30-min TTL.	`app/auth_provider.py`, `app/routers/auth.py`, `app/security.py`
RBAC	Server-side, **default-deny**, resolved from PostgreSQL (never from IdP). CI enforces every `/api` route maps to an explicit permission.	`app/rbac_matrix.py`, `tests/test_route_coverage.py`
DB isolation	Separate `caul_dev` / `caul_staging` databases, **least-privilege app roles** (`caul_dev_user`/`caul_staging_user`), owner-applied grants.	`.env`, `scripts/apply_grants.py`
Audit	Tamper-**evident** hash-chained `audit_events`; **INSERT-only at the DB level** (UPDATE/DELETE revoked from app role); per-env verify cron (HMAC bearer).	`app/audit.py`, `app/routers/cron.py`, `tests/test_hardening.py`
Emergency / kill switch	Global + granular **pause/resume**, queue cancel/drain, **revoke**, rollback (stub). Pause scope can gate a connector.	`app/routers/emergency.py`, `app/approvals.py` (`active_pause_blocking`)
Connector pattern	`BaseConnector` ABC + `run_contract_suite()` gate (authorization default-deny, pause/revoke block, timeout/failure = no side-effect, idempotency, audit record). **All connectors "Not Connected".**	`app/connectors/base.py`, `tests/test_connector_contract.py`
Secrets	Env-only (names): `JWT_SECRET`, `WEBHOOK_CRON_SECRET[_DEV|_STAGING]`, `*_DATABASE_URL`, `CORS_ORIGINS`. No external API keys present.	`backend/.env`
Deploy / rollback	Deployment readiness = PASS; CORS auto-updated at deploy; CI gate on `main`. Rollback via platform checkpoints (off-box export deferred, needs approval).	`.github/workflows/ci.yml`, `docs/BACKUP_RESTORE.md`, `docs/OFFBOX_CHECKPOINT_EXPORT_PROPOSAL.md`

CAUL AI unknowns / dependencies for integration
- **No production IdP yet (Phase 1B).** Service-to-service trust (CAUL <-> Deal Flow OS) needs a real credential mechanism that does **not** exist today.
- The connector contract is **action/execute-oriented**; a **read-only metrics *pull*** capability is not yet modeled (proposed in §2).
- No outbound-HTTP client, scheduler for external pulls, or metrics-storage table exists yet.

1B. Deal Flow OS — ACCESS GAP (reported, not assumed)

Only the **public** site (https://dealflowos.app) was observed. Treat everything below as *public-surface only*; internals are **UNKNOWN pending authorized access.**

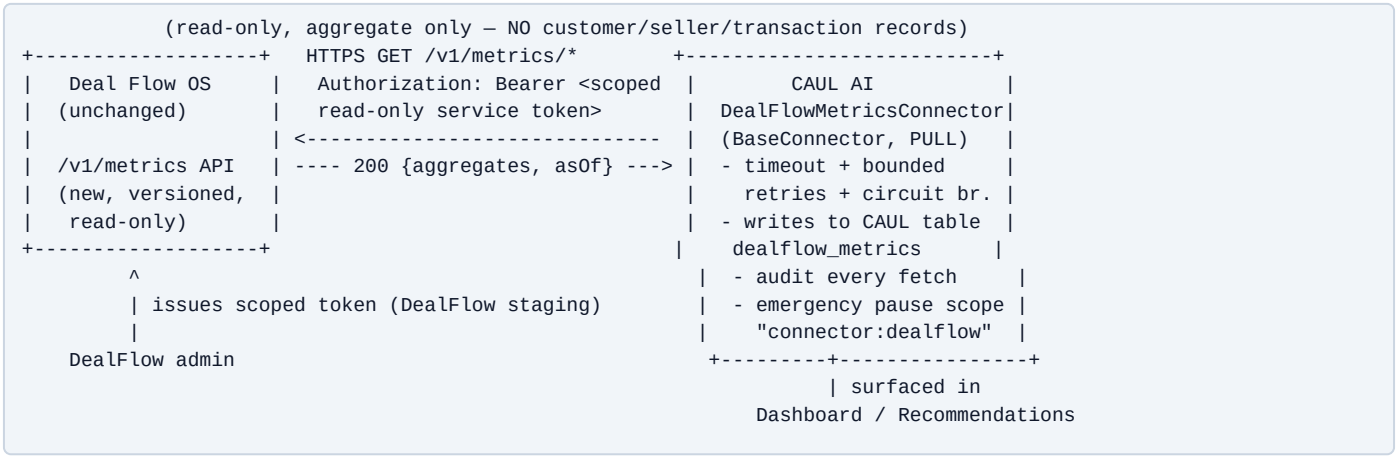
Observed (public)	Detail
Product	Real-estate **wholesaling OS**: motivated-seller finder, deal analyzer (ARV/MAO/70% rule), cash-buyer marketplace, offer generator, deal pipeline.
AI	Marketed as **"Claude Sonnet 4.5 powered"** AI Acquisitions Manager.
Accounts/billing	Public **register / login**, **free trial -> paid** (subscription implied). Billing provider **UNKNOWN** (Stripe likely — to confirm).
Coverage	"All 50 states", "10 lead types".

Deal Flow OS unknowns (require authorized audit): repository & stack (DB engine, framework), hosting/monitoring, authentication method, existing public/internal **APIs & versioning**, **billing/analytics source of truth** (Stripe? internal?), webhook capability, tenant model, deployment workflow, rate limits.

---

2. Proposed system & data-flow + API contract

Direction: Deal Flow OS is the **source of truth**; CAUL AI is a **read-only consumer** of *aggregate* metrics. Deal Flow OS must keep working if CAUL AI is down (no runtime dependency on CAUL).



Proposed API contract (to be implemented *in Deal Flow OS staging*, Phase 1 — not now):

- `GET /v1/metrics/summary` -> `{ "as_of": ISO8601, "tenant": "...", "metrics": { … aggregates … } }`
- `GET /v1/metrics/subscriptions?window=30d` -> aggregate counts only.
- **Versioned** (`/v1/`), **read-only**, **aggregate-only** (no row-level PII), **tenant-scoped**, idempotent, cacheable (`ETag`/`asOf`).
- **AuthN:** scoped **read-only service token** (or mTLS/signed JWT) issued by Deal Flow OS; least-privilege; rotatable; staging-only to start.
- **Limits:** server-side rate limit + CAUL-side timeout (e.g. 5s), **bounded retries** (e.g. 3, jittered), circuit-breaker, no unbounded polling.

CAUL AI side (Phase 1, staging only):

- New `MetricsConnector` capability on the connector contract (read-only `fetch(metric_set) -> aggregates`), still gated by `run_contract_suite()` + a new **`metrics:read`** permission.
- New **least-privilege service role** `DealFlow Metrics Reader` (holds only `metrics:read`; inherits `SERVICE_IDENTITY_FORBIDDEN`).
- New table `dealflow_metrics` (aggregate values + `as_of` + source hash); every fetch writes an audit event; kill switch = emergency pause scope `connector:dealflow`.

---

3. Security & privacy risks -> mitigations

Risk	Mitigation
No CAUL production IdP (stub only) — cannot establish real S2S identity today	**Blocker for Phase 1 production.** Either (a) decide Phase 1B IdP first, or (b) scope Phase 1 to **staging-only** with a short-lived signed service token. Keep auth stub labels.

Risk	Mitigation
PII / sensitive record leakage (sellers, buyers, contracts)	Contract is **aggregate-only**; schema validation rejects any row-level/PII field; DealFlow endpoint returns counts/sums only.
Over-broad credential scope	Dedicated read-only token, least privilege, rotation, staging-first, stored as CAUL secret (env), never in code.
Availability coupling	CAUL pulls async on a schedule; DealFlow has **zero** runtime dependency on CAUL; CAUL degrades gracefully (shows "stale as_of").
Tenant cross-contamination	Token scoped to one tenant; CAUL stores `tenant` + validates it matches token.
Replay / tampering of inbound data	Store source hash + `as_of`; audit each fetch; reject stale/out-of-order payloads.
Secret sprawl / CORS	Reuse env-only secret pattern; no new CORS origins; connector is server-to-server (no browser exposure).
Uncontrolled spend (LLM/egress)	Phase 0 = $0. Phase 1 = metered reads only; **any paid service requires separate approval.**

---

4. Metrics & source-of-truth mapping

(Source of truth and formulas must be confirmed during the authorized Deal Flow OS audit — marked ■.)

Metric	Likely source of truth	Formula (draft)	Cadence	Access needed
Registered accounts	DealFlow DB (users) ■	count(users)	daily	read aggregate
Active accounts	DealFlow analytics ■	count(active in 30d)	daily	read aggregate
Paying subscribers	Billing (Stripe?) ■	count(active subscriptions)	daily	read aggregate
MRR / ARR	Billing ■	Σ active sub amounts (normalized monthly); ARR = MRR×12	daily	read aggregate
New subscriptions	Billing ■	count(new subs in window)	daily	read aggregate
Cancellations / churn	Billing ■	cancels ÷ active at period start	weekly	read aggregate
Trial -> paid conversion	Billing + users ■	converted ÷ trials started	weekly	read aggregate
Activation	DealFlow analytics ■	reached "first key action" ÷ signups	weekly	read aggregate
Feature adoption	DealFlow analytics ■	% using module X	weekly	read aggregate
Acquisition cost (CAC)	DealFlow + marketing spend ■	spend ÷ new customers	monthly	read aggregate (+ spend source ■)

---

5. Staged implementation, test & rollback plan *(for approval — not executed)*

Phase 1 (staging only, after approval):
1. Deal Flow OS: add versioned **read-only** `/v1/metrics/*` in **staging**; issue a scoped read-only token. *(DealFlow team / separate approval.)*
2. CAUL AI: add `metrics:read` perm + `DealFlow Metrics Reader` service role + `MetricsConnector` + `dealflow_metrics` table + scheduled pull — behind the existing kill switch. All in CAUL **staging**.

Test plan (isolated staging + synthetic data): contract tests, authN (valid/invalid/expired token), authZ/default-deny, **tenant isolation**, reconciliation (CAUL aggregates == DealFlow source), load/rate-limit, network-failure (timeout/retry/circuit-breaker), secret handling, **kill-switch & rollback**.

Rollback (independent): disable via emergency pause `connector:dealflow`; revoke the DealFlow token; feature-flag the connector off; CAUL continues on last-good `as_of`; **no DealFlow change required.**

---

6. Estimated incremental infrastructure / operating cost

- **Phase 0: $0** (discovery only).
- **Phase 1 (staging):** effectively negligible — a scheduled read job + small metrics table + minor egress. **No new paid services.**
- **Production (later, separate approval):** metered API reads + scheduler; cost depends on refresh cadence. **Any paid dependency or outreach/LLM spend is out of scope until explicitly approved.**

---

7. Approvals & access required before Phase 1

1. **Executive written approval** to begin a limited, **staging-only** Phase 1 connector.
2. **Authorized read-only audit access** to Deal Flow OS: repo/stack, API docs, DB engine, **billing/analytics source of truth**, hosting/monitoring, deployment workflow, tenant model, rate limits.
3. A **scoped read-only service token** issued in **Deal Flow OS staging** (least-privilege, rotatable).
4. Decision on CAUL AI trust model: **Phase 1B IdP first** vs. an **interim signed service-token** for staging.
5. Confirmation of the **metrics source-of-truth & formulas** in §4.
6. Preserve all CAUL AI Phase 1A gates (already accepted) — no regressions.

STOP — Phase 0 complete

Per the brief, **work stops here.** No code in either app was modified; nothing was deployed; no spend incurred. Requesting **written approval** (and the access in §7) before any limited, staging-only Phase 1 connector work begins.